



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Egotistical Bank

RÉFÉRENCE

SKS-2026-R003

VERSION

1.0

DATE

18 mai 2026

TYPE D'AUDIT

Boîte noire (sans accès initial fourni)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	13
10. Indicateurs de Compromission & Artefacts	14
11. Plan de Remédiation	15
12. Conclusion	16

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	contact@sk-security.fr	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
smith	hsmith@egotistical-bank.local	+33xxxxxxxxx	Admin

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le domaine Active Directory EGOTISTICAL-BANK.LOCAL a été compromis dans sa totalité depuis une position sans accès initial, via une chaîne d'attaque en trois étapes : énumération des comptes de domaine via Kerbrute, exploitation d'une absence de pré-authentification Kerberos (AS-REP Roasting) sur le compte fsmith pour obtenir un hash crackable offline, puis récupération d'un mot de passe en clair stocké dans la base de registre Windows (clé Winlogon) permettant l'accès au compte de service svc_loanmgr. Ce compte dispose du privilège DCSync sur le domaine, ce qui a permis l'extraction de l'intégralité des hashes NTLM via secretdump, incluant le hash Administrator. L'accès au contrôleur de domaine SAUNA.EGOTISTICAL-BANK.LOCAL a été obtenu avec les privilèges Administrator via Pass-the-Hash, et l'ensemble des secrets Kerberos et hashes NTLM du domaine doit être considéré comme compromis. La chaîne repose sur trois misconfigurations indépendantes dont le chaînage conduit à une compromission de domaine complète sans interaction utilisateur au-delà de l'ouverture de session de fsmith sur le système.

Scope & Méthodologie

Périmètre

Cible	Type	IP/URL
SAUNA.EGOTISTICAL-BANK.LOCAL	Contrôleur de domaine Windows Server 2019	10.129.34.45
Port 53	DNS	10.129.34.45:53
Port 80	HTTP — Microsoft IIS 10.0	10.129.34.45:80
Port 88	Kerberos	10.129.34.45:88
Port 389	LDAP	10.129.34.45:389
Port 445	SMB	10.129.34.45:445
Port 5985	WinRM	10.129.34.45:5985

Périmètre négatif

Les tests ont été limités aux services exposés sur la cible 10.129.34.45. Aucun test n'a été conduit sur les postes de travail utilisateurs, les infrastructures réseau périphériques (firewall, switches, VPN), les applications tierces non exposées directement sur le système cible, ni sur d'éventuels autres domaines ou forêts Active Directory. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'audit des GPO, des politiques de mots de passe et de la configuration DNS n'a pas fait l'objet d'un examen exhaustif.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte noire (sans accès initial fourni)
Période	16-17 mai 2026
Accès fournis	Aucun — reconnaissance depuis l'extérieur du périmètre

Méthodologie

Reconnaissance et énumération de services : scan nmap complet sur l'ensemble des ports TCP avec détection de version et scripts par défaut, révélant une surface d'attaque Active Directory standard (DNS, Kerberos, LDAP, SMB, WinRM). Identification de la version IIS et du domaine EGOTISTICAL-BANK.LOCAL via les bannières LDAP. Vérification de l'accès anonyme LDAP via nuclei.

Énumération des comptes de domaine via Kerbrute : bruteforce des noms d'utilisateurs valides sur le port Kerberos (88) à l'aide de la wordlist xato-net-10-million-usernames, permettant l'identification de fsmith, hsmith et administrator comme comptes valides du domaine.

AS-REP Roasting — obtention du hash fsmith : requête AS-REP via impacket-GetNPUsers sur les comptes énumérés, révélant que le compte fsmith n'a pas la pré-authentification Kerberos activée (UF_DONT_REQUIRE_PREAUTH). Récupération du hash krb5asrep\$23 et crack offline via john avec la wordlist rockyou.txt — mot de passe obtenu en clair.

Pivot vers svc_loanmgr — credentials en clair dans la base de registre : depuis le shell WinRM fsmith, lecture de la clé de registre HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon révélant les credentials du compte svc_loanmgr (DefaultUserName / DefaultPassword) stockés en clair. Validation de l'accès WinRM via nxc.

DCSync — dump complet du domaine : le compte svc_loanmgr dispose du privilège DCSync identifié via BloodHound. Exécution de secretdump via impacket avec les credentials svc_loanmgr pour extraire l'intégralité des hashes NTLM et clés Kerberos du domaine via le protocole DRSUAPI.

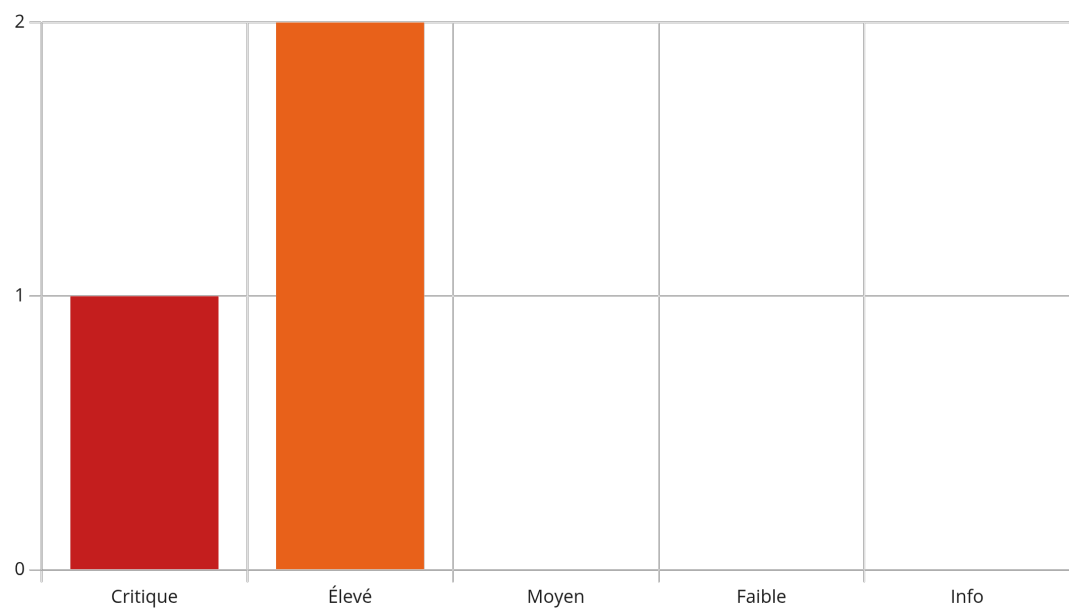
Post-exploitation : accès Administrator via Pass-the-Hash avec evil-winrm en utilisant le hash NTLM extrait.

Outils utilisés

Outil	Usage
nmap	Scan de ports et détection de services
whatweb	Fingerprinting de l'application web IIS
nuclei	Détection de l'accès anonyme LDAP
kerbrute	Énumération des comptes de domaine valides via Kerberos
impacket-GetNPUsers	AS-REP Roasting — extraction du hash krb5asrep fsmith
john	Crack offline du hash AS-REP avec rockyou.txt
evil-winrm	Shell interactif WinRM — accès fsmith et Administrator
nxc (netexec)	Validation des credentials svc_loanmgr via WinRM
bloodhound-python	Collecte BloodHound — identification du privilège DCSync de svc_loanmgr
impacket-secretsdump	DCSync — dump des hashes NTLM et clés Kerberos du domaine

Sommaire des Vulnérabilités

Au cours de cet audit, **1 critique(s)** , **2 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-007	Privlège DCSync accordé à un compte de service — dump complet du domaine via svc_loanmgr	CRITICAL	9.1	SAUNA.EGOTISTICAL-BANK.LOCAL — Active Directory EGOTISTICAL-BANK.LOCAL
SKS-2026-008	Credentials de compte de service stockés en clair dans la base de registre Windows (Winlogon)	HIGH	8.8	SAUNA.EGOTISTICAL-BANK.LOCAL — 10.129.34.45
SKS-2026-009	AS-REP Roasting — absence de pré-authentification Kerberos sur le compte fsmith	HIGH	8.1	SAUNA.EGOTISTICAL-BANK.LOCAL — Active Directory EGOTISTICAL-BANK.LOCAL — compte fsmith

Introduction

SK Security a conduit un audit de sécurité en boîte noire sur le domaine EGOTISTICAL-BANK.LOCAL, depuis une position externe sans accès fourni, en ciblant l'infrastructure exposée sur 10.129.34.45 (SAUNA). L'objectif de la mission était d'évaluer la résistance de l'infrastructure aux attaques d'élévation de privilèges sur les composants Active Directory, avec un focus sur les mécanismes d'authentification Kerberos, la gestion des comptes de service et la protection des secrets stockés localement. La mission a été conduite depuis la reconnaissance initiale jusqu'à la compromission complète du contrôleur de domaine.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 3 findings combinés — l'AS-REP Roasting fournit un premier accès authentifié qui déverrouille la lecture de la base de registre, depuis laquelle les credentials DCSync permettent la compromission totale du domaine, portant le risque réel bien au-delà du CVSS isolé de chaque finding.

CWE CWE-269 (Improper Privilege Management)

ACTIF SAUNA.EGOTISTICAL-BANK.LOCAL — Active Directory EGOTISTICAL-BANK.LOCAL

VECTEUR CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Description

Le compte de service svc_loanmgr dispose des droits de réplication d'annuaire DS-Replication-Get-Changes et DS-Replication-Get-Changes-All sur la partition de domaine, droits normalement réservés aux contrôleurs de domaine et aux comptes d'administration Tier 0. Ces droits permettent d'invoquer le protocole DRSUAPI pour solliciter une réplication des secrets d'annuaire depuis n'importe quel poste du réseau, sans nécessiter d'accès physique ou interactif au contrôleur de domaine. Un attaquant contrôlant le compte svc_loanmgr peut ainsi exécuter secretdump pour extraire l'intégralité des hashes NTLM de tous les comptes du domaine, incluant le compte krbtgt et le compte Administrator, sans déposer de binaire sur le contrôleur de domaine et sans générer d'alerte liée à un accès direct au fichier ntds.dit.

Chaîne d'exploitation

Depuis les credentials svc_loanmgr, exécution du DCSync via impacket-secretsdump :

```
secretsdump.py EGOTISTICAL-BANK.LOCAL/svc_loanmgr: '[REDACTED]'@10.129.34.45
```

Accès Administrator via Pass-the-Hash avec le hash NTLM extrait :

```
evil-winrm -i 10.129.34.45 -u Administrator -H [REDACTED]
```

Impact

L'exécution du DCSync fournit l'intégralité des hashes NTLM et clés Kerberos de tous les comptes du domaine, incluant Administrator, krbtgt, HSmith, FSmith, svc_loanmgr et le compte machine SAUNA\$. La possession du hash krbtgt permet la forge de Golden Tickets valides pour n'importe quel compte avec une durée de vie arbitraire. La possession du hash Administrator permet un accès immédiat au contrôleur de domaine via Pass-the-Hash. La compromission est totale et persistante tant que la double rotation krbtgt n'est pas effectuée.

Recommandation

Révoquer immédiatement les droits DS-Replication-Get-Changes et DS-Replication-Get-Changes-All attribués à svc_loanmgr via les ACL de la partition de domaine. Auditer l'ensemble des comptes non-DC disposant de droits de réplication via BloodHound (edge DCSync) et la requête LDAP sur les ACL de la racine du domaine. Confiner svc_loanmgr au strict périmètre fonctionnel requis par l'application associée. Activer l'audit des opérations de réplication (Event ID 4662 avec GUID {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}). Réinitialiser l'ensemble des mots de passe du domaine et effectuer la double rotation du compte krbtgt.

Références

- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html#dcsync>
- <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4662>
- <https://www.thehacker.recipes/ad/movement/credentials/dumping/dcsync>
- <https://cwe.mitre.org/data/definitions/269.html>

CWE CWE-312 (Cleartext Storage of Sensitive Information) ACTIF SAUNA.EGOTISTICAL-BANK.LOCAL — 10.129.34.45

VECTEUR **CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H**

Description

La clé de registre HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon contient les valeurs DefaultUserName et DefaultPassword peuplées avec les credentials du compte de service EGOTISTICALBANK\svc_loanmanager en clair. Cette configuration est généralement associée à la fonctionnalité d'ouverture de session automatique Windows (Autologon), qui stocke le mot de passe en clair dans cette clé accessible en lecture par tout utilisateur authentifié disposant d'un accès local ou distant au système. Depuis un shell WinRM obtenu avec un compte de faible privilège (fsmith), la lecture de cette clé est réalisable en une seule commande sans élévation de privilèges préalable, fournissant immédiatement les credentials du compte de service.

Chaîne d'exploitation

Depuis le shell WinRM fsmith, lecture de la clé Winlogon :

```
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon"
```

Le résultat expose en clair DefaultUserName = EGOTISTICALBANK\svc_loanmanager et DefaultPassword = [REDACTED]. Validation de l'accès WinRM avec ces credentials :

```
nxc winrm 10.129.34.45 -u svc_loanmgr -p '[REDACTED]'
```

Impact

Les credentials de svc_loanmgr obtenus permettent un accès WinRM direct au contrôleur de domaine avec ce compte de service. Compte tenu du privilège DCSync dont dispose svc_loanmgr (SKS-2026-007), ce finding constitue le pivot central de la chaîne d'attaque : il transforme un accès utilisateur de faible privilège en capacité de dump complet du domaine. Tout compte disposant d'un accès en lecture à la base de registre locale — via WinRM, RDP, ou toute autre session authentifiée — peut reproduire cette extraction.

Recommandation

Supprimer immédiatement les valeurs DefaultUserName et DefaultPassword de la clé Winlogon sur SAUNA. Auditer l'ensemble du parc pour identifier d'autres systèmes configurés avec l'Autologon Windows via la clé Winlogon ou la clé LSA DefaultPassword. Désactiver la fonctionnalité Autologon sur les systèmes sensibles (contrôleurs de domaine, serveurs Tier 0 et Tier 1). Réinitialiser le mot de passe svc_loanmgr. Si l'Autologon est fonctionnellement requis, utiliser la fonctionnalité Autologon chiffrée via DPAPI ou un mécanisme de gestion de secrets dédié.

Références

- <https://learn.microsoft.com/en-us/troubleshoot/windows-server/user-profiles-and-logon/turn-on-automatic-logon>
- <https://www.thehacker.recipes/ad/recon/ms-rpc>
- <https://cwe.mitre.org/data/definitions/312.html>

CWE CWE-287 (Improper Authentication)

ACTIF SAUNA.EGOTISTICAL-BANK.LOCAL — Active Directory EGOTISTICAL-BANK.LOCAL — compte fsmith

VECTEUR CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Le compte fsmith (Fergus Smith) est configuré avec l'attribut UF_DONT_REQUIRE_PREAUTH, ce qui désactive la pré-authentification Kerberos. Lorsque cette option est active, le KDC répond à toute requête AS-REQ adressée pour ce compte sans exiger de preuve d'identité préalable, en retournant un ticket AS-REP chiffré avec la clé dérivée du mot de passe du compte. Ce ticket est récupérable sans authentification préalable et peut être soumis à un crack offline. Depuis une position réseau ayant accès au port Kerberos (88), impacket-GetNPUsers permet d'extraire le hash krb5asrep\$23 de fsmith en une seule requête. Le hash a été cracké en quelques secondes avec john et la wordlist rockyou.txt, le mot de passe étant présent dans les listes communes.

Chaîne d'exploitation

Énumération des comptes sans pré-authentification Kerberos :

```
impacket-GetNPUsers EGOTISTICAL-BANK.LOCAL/ -no-pass -usersfile users.txt -dc-ip 10.129.34.45
```

Le hash AS-REP de fsmith est retourné :

```
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL : [REDACTED]
```

Crack offline du hash :

```
john asrepfsmith.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Mot de passe obtenu en clair : [REDACTED]. Connexion WinRM :

```
evil-winrm -i 10.129.34.45 -u fsmith -p '[REDACTED]'
```

Impact

L'accès au shell WinRM fsmith fournit un point d'entrée authentifié sur le contrôleur de domaine depuis lequel la base de registre est lisible. Ce finding constitue le premier maillon de la chaîne d'attaque conduisant à l'extraction des credentials svc_loanmgr (SKS-2026-008) et au DCSync complet du domaine (SKS-2026-007). La technique est entièrement offline pour la phase de crack, ne nécessite aucune interaction utilisateur et est exécutable depuis n'importe quelle position réseau atteignant le port 88, y compris depuis Internet si ce port est exposé.

Recommandation

Activer la pré-authentification Kerberos sur le compte fsmith (décocher l'option "Do not require Kerberos preauthentication" dans les propriétés du compte). Auditer l'ensemble des comptes du domaine disposant de l'attribut UF_DONT_REQUIRE_PREAUTH via la requête LDAP : (userAccountControl:1.2.840.113556.1.4.803:=4194304). Implémenter une politique de mots de passe robuste (longueur minimale 15 caractères, complexité, rotation) pour limiter le risque de crack offline. Activer la journalisation des requêtes AS-REP anormales (Event ID 4768 avec code d'erreur 0x0).

Références

- <https://www.thehacker.recipes/ad/movement/kerberos/asreproast>
- <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4768>
- <https://bloodhound.readthedocs.io/en/latest/data-analysis/nodes.html#users>
- <https://cwe.mitre.org/data/definitions/287.html>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Scan nmap complet — identification des services AD exposés	10.129.34.45
2	Énumération Kerbrute — identification des comptes fsmith, hsmith, administrator	10.129.34.45:88
3	AS-REP Roasting via impacket-GetNPUsers — hash krb5asrep fsmith obtenu	10.129.34.45:88
4	Crack offline du hash fsmith via john — mot de passe en clair obtenu	localhost
5	Connexion WinRM fsmith — accès shell interactif	10.129.34.45:5985
6	Lecture de la clé de registre Winlogon — credentials svc_loanmgr en clair	10.129.34.45
7	Validation accès WinRM svc_loanmgr via nxc	10.129.34.45:5985
8	Collecte BloodHound — identification du privilège DCSync de svc_loanmgr	10.129.34.45:389
9	DCSync via secretsdump — dump complet des hashes NTLM et clés Kerberos	10.129.34.45
10	Accès Administrator via Pass-the-Hash — evil-winrm	10.129.34.45:5985

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Compte AD	fsmith — UF_DONT_REQUIRE_PREAUTH activé	Activer la pré-authentification Kerberos sur le compte
Clé de registre	HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon — DefaultPassword en clair	Supprimer les valeurs DefaultUserName et DefaultPassword — auditer les connexions automatiques sur l'ensemble du parc
Credentials	svc_loanmgr / [REDACTED] stockés en clair dans la base de registre	Réinitialiser le mot de passe svc_loanmgr — auditer les droits DCSync du compte
Privilège AD	DCSync accordé à svc_loanmgr	Révoquer les droits DS-Replication-Get-Changes et DS-Replication-Get-Changes-All sur svc_loanmgr
Hashes NTLM	Intégralité des hashés du domaine compromis (Administrator, krbtgt, HSmith, FSmith, svc_loanmgr, SAUNA\$)	Réinitialiser tous les mots de passe du domaine — double rotation krbtgt

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-007	Privilège DCSync accordé à un compte de service — dump complet du domaine via svc_loanmgr	Critique	Révoquer les droits DCSync de svc_loanmgr — réinitialiser tous les mots de passe du domaine — double rotation krbtgt	Immédiat
SKS-2026-008	Credentials de compte de service stockés en clair dans la base de registre Windows (Winlogon)	Élevé	Supprimer DefaultPassword de Winlogon — réinitialiser le mot de passe svc_loanmgr — auditer l'Autologon sur le parc	48h
SKS-2026-009	AS-REP Roasting — absence de pré-authentification Kerberos sur le compte fsmith	Élevé	Activer la pré-authentification Kerberos sur fsmith — auditer tous les comptes avec UF_DONT_REQUIRE_PREAUTH	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission du domaine EGOTISTICAL-BANK.LOCAL s'est déroulée en trois pivots depuis une position sans accès initial. L'absence de pré-authentification Kerberos sur le compte fsmith a permis l'obtention d'un hash AS-REP crackable offline, fournissant un premier shell WinRM. Depuis ce contexte, un mot de passe stocké en clair dans la clé de registre Winlogon a exposé les credentials du compte de service svc_loanmgr, lequel dispose du privilège DCSync sur le domaine — permettant l'extraction de l'intégralité des hashes NTLM et clés Kerberos via secretsdump.

L'accès Administrator a été obtenu par Pass-the-Hash en une seule opération. L'ensemble des comptes, secrets Kerberos et ressources jointes au domaine EGOTISTICAL-BANK.LOCAL doit être considéré comme compromis. La persistance via le hash krbtgt permet la forge de Golden Tickets pour une durée indéterminée si la double rotation n'est pas effectuée.

Le **niveau de risque global est CRITIQUE**. La remédiation prioritaire porte sur la révocation immédiate du privilège DCSync de svc_loanmgr, la suppression des credentials en clair de la base de registre, l'activation de la pré-authentification Kerberos sur tous les comptes concernés, et la réinitialisation forcée de l'ensemble des mots de passe du domaine incluant la double rotation krbtgt.

Finding	Priorité	Délai de retest
SKS-2026-007 — DCSync sur svc_loanmgr	Critique	Dans les 48h suivant la correction
SKS-2026-008 — Credentials en clair Winlogon	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-009 — AS-REP Roasting fsmith	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

contact@sk-security.fr